

Vulnerability Assessment Report

1st January 2026

System Description

The system under review is a publicly accessible MySQL database server for an e-commerce company. The server stores customer data, campaign information, and analytics. It runs on a Linux operating system with a powerful CPU and 128GB of memory. It is configured with IPv4 networking and has been openly accessible to the public since the company’s launch.

Scope

This assessment focuses on the risks associated with the database server’s public exposure. The scope covers confidentiality, integrity, and availability of the data stored on the server. It does not include physical security or unrelated internal IT systems. The assessment is guided by *NIST SP 800-30 Rev.1* methodology.

Purpose

The purpose of this vulnerability assessment is to identify security risks posed by the publicly accessible database server and provide recommendations to reduce exposure. Securing this system is critical because a breach could result in loss of customer trust, regulatory penalties, and disruption of core business operations.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Hacker</i>	<i>Unauthorized access and data exfiltration</i>	<i>4</i>	<i>5</i>	<i>10</i>
<i>Malicious Insider</i>	<i>Alteration or deletion of critical data</i>	<i>2</i>	<i>4</i>	<i>8</i>
<i>Competitor</i>	<i>Denial of Service (DoS) attack</i>	<i>3</i>	<i>3</i>	<i>9</i>
<i>Customer</i>	<i>Alter/Delete critical information</i>	<i>1</i>	<i>3</i>	<i>3</i>

Approach

I conducted this assessment by first reviewing the system description and scope. Using *NIST SP 800-30 Rev.1* as a guide, I identified relevant threat sources and events. Likelihood and severity were evaluated based on the server's public exposure, the sensitivity of the data, and potential business impact. Risks were then calculated by multiplying likelihood and severity scores.

Remediation Strategy

To address the identified risks, the following controls are recommended:

- Restrict public access to the database and implement secure remote access (VPN + Multi-Factor Authentication).
- Apply the principle of least privilege to database accounts and regularly review permissions.
- Implement Defense in Depth through network segmentation, firewall rules, and intrusion detection systems.
- Enable strong encryption for data in transit (TLS) and at rest.
- Conduct regular vulnerability scans, patching, and monitoring of the server.

These measures will significantly reduce the attack surface while maintaining necessary business functionality for remote employees.